

현행 기준 정리 — RQ · 평가지표 · 데이터셋

기준일: 2026-08-24 · 대상 브랜치 `phase1-data-acquisition`

이 문서의 목적: Phase 1~12 에서 쌓인 기록과 Phase 13(2026-08-13 교수 미팅) 이후의 개편이 섞여 "지금 무엇이 유효한지"를 매번 되짚어야 하는 상태를 끝내기 위한 **통합 참조본**이다. 특히 ① **단일 RGB CNN 이 제안 모델이던 시절의 RQ 문구**, ② **MCC 중심의 옛 지표**, ③ **Kaggle+CSIC 조합의 옛 데이터셋** 세 가지가 혼동의 원인이므로 이 셋을 시기별로 분리해 정리한다.

⚠ 이 문서는 새 사실을 만들지 않는다. 모든 수치·결정에는 원 출처 문서를 표기했고, 원문과 어긋나면 원문이 옳다. 단일 진실 소스 지도는 §0.2.

0. 읽는 법

0.1 세 개의 시기 — 이것만 구분하면 대부분의 혼동이 사라진다

시기	기간	제안 모델	헤드라인 지표	주 데이터셋
1기	Phase 1~6 (~2026-07-15)	단일 CNN (grayscale 1채널)	Accuracy · Macro-F1 · ROC-AUC	Kaggle 페이로드 4클래스
2기	Phase 7~12 (2026-07-15 ~ 08-12)	2026-08-02 부터 캐스케이드	MCC · PR-AUC · benign-evasion	<code>payload_4class_csicnorm</code> (Normal=CSIC 실패픽)
3기 (현행)	Phase 13~ (2026-08-13 ~)	캐스케이드 (변동 없음)	Macro-F1 · PR-AUC · TPR@FPR · pAUC · 경보부하 · ECE	SR-BH 2020 + Data 2025 외부검증 + CSIC 2010 legacy

핵심 3줄 요약

- 1. **제안 모델은 2026-08-02 부터 캐스케이드다.** 단일 RGB CNN 은 제안 지위를 내려놓고 **비교 기준**이 됐다.
- 2. **MCC 는 2026-08-13 부로 완전히 제거됐다.** 옛 문서의 MCC 수치는 2기의 **실측 기록**으로 읽고, 새 측정과 섞지 않는다.
- 3. **데이터셋은 아직 교체되지 않았다.** SR-BH 2020 채택은 **확정**됐으나 다운로드부터가 미착수다 → 현재 `experiments/results/` 의 수치는 전부 2기 기준이며 **재측정 대상**이다.

0.2 단일 진실 소스 지도 — 어긋나면 어느 쪽이 옳은가

알고 싶은 것	진실 소스	비고
RQ 표 · 기여 문구 · 논문 목차	<code>docs/web_attack_image_cnn_thesis_design.md</code> (마스터)	Phase 문서와 어긋나면 마스터를 고친다
현행 평가지표 · 데이터셋 결정	<code>docs/13_dataset_metric_revision_design.md</code>	마스터 §6.1-§3 보다 이쪽이 최신
지표별 1차 출처 (인용)	<code>docs/13 §1.6</code>	원문 대조 완료(2026-08-23). 논문 인용은 이 표를 그대로 쓴다
저 FPR 지표의 성립 조건	<code>docs/13 §1.7</code>	표본 수 제약
수집 논문 목록·서지	<code>docs/12 §1.3</code>	<code>docs/thetics/</code> 는 <code>.gitignore</code> → 추적본은 이 표 뿐

알고 싶은 것	진실 소스	비고
실측 수치	experiments/results/*.json	⚠️ 전체 .gitignore, 재생성으로 확보
그림	docs/figures/	추적·커밋 대상
코드 관례·함정	CLAUDE.md	트랙 추가 "5곳", tag 규칙 등
논문 서술용 흐름 정리	docs/reports/thesis_onepass_2026-08-12.html	⚠️ Phase 13 이전 판 — 지표·데이터셋 절은 이 문서로 갱신해 읽을 것
지나간 시점의 기록	docs/archive/	⚠️ 현행 기준 아님 . 참조가 필요하면 내용을 현행 문서로 옮기고 원본만 남긴다

1. 지금 유효한 것 / 폐기된 것 (한 표)

항목	❌ 더 이상 쓰지 않음	✅ 현행
제안 모델	단일 RGB CNN	캐스케이드(1차 RGB CNN + 2차 char-CNN, τ 게이트)
모델 호칭	제안 CNN (금지어)	RGB CNN / gray CNN / 얇은 CNN / 캐스케이드
단일 요약 기준 지표	MCC	Macro-F1
지표 근거 문헌 (1차)	MDPI <i>Technologies</i> 14(1):54, 2026 · arXiv:2512.19203	Arp et al. USENIX Sec 2022 / CACM 67(11):104–112, 2024 (+ 지표별 개별 출처, §4.4)
ECE 의 근거	~~Arp et al.~~ (오귀속)	Naeini AAAI 2015 · Guo ICML 2017 (+ CalexNet)
주 데이터셋	payload_4class_csicnorm	SR-BH 2020 (미착수 — §5.2)
외부 검증셋	없음	Data 2025 10(11):186 (미착수)
CSIC 2010	주 트랙	legacy 비교 기준으로 강등(삭제 아님)
ViT / hybrid	—	미채택 확정(F13)
조기종료 1차 (M4)	—	미채택 확정(한계로 정직 보고)
RQ1 의 답	~~"이미지가 더 낫다"~~	"아니오" — 그대로 보고(HARKing 금지, §3.3)

2. 용어 — 실제로 사고가 났던 지점

근거: 마스터 §5.1, docs/10 §0.1, CLAUDE.md

용어	뜻	주의
캐스케이드 (cascade)	1차 RGB CNN 전량 → 확신도 $< \tau$ 인 소수만 2차 char-CNN. 배치 구조이며 새 학습이 없다	제안 모델은 이것
hybrid	CNN stem + Transformer 로 된 모델 아키텍처(docs/08, ViT 계열)	⚠️ cascade 와 다른 것. 이름 섞지 말 것. 미채택
RGB CNN	48×48×3 단일 CNN (93,988 파라미터)	캐스케이드의 1차 부품이자 비교 기준
gray CNN	위의 1채널 판본	1기의 기본형

용어	뜻	주의
얇은 CNN	채널과 무관하게 아키텍처를 지칭	Conv 32→64→128, BN, ReLU, MaxPool ×3, GAP, FC
~~제안 CNN~~	—	❌ 금지어. (ㄱ)제안 모델과 (ㄴ)1차 부품 두 뜻으로 읽혀 실제 혼동이 났다

⚠️ 옛 회피 수치 0.594 / 0.5944 / 0.0022 는 gray 실측이다. RGB 기준선은 0.5981(2026-08-02 측정).

3. 연구 질문 (RQ)

3.1 번호 규약 — 재배열 금지

RQ 번호가 파일명에 박혀 있다(05_evasion_attacks_rq2 , 06_..._rq4 , 10_..._rq3). 전면 재번호는 파일명 + 12개 문서 136곳의 상호참조를 혼든다. → ID 는 고정, 새 질문은 뒤 번호로 추가. 논문 본문의 서술 순서만 §3.4 를 따른다.

3.2 현행 RQ 표 (마스터 §1.2, 2026-08-06 개정)

ID	질문	2기 기준 상태	Phase 13 이후
RQ1	웹 공격 페이로드(SQLi, XSS, CmdI)를 바이트 이미지로 변환한 탐지는, 텍스트 기반 모델(char-CNN/BiLSTM, TF-IDF+전통 ML) 대비 정확도-비용 Pareto 상 어디에 위치하는가?	✅ 답 완료 — 음성 결과 (F1·F2·F3)	⚠️ 재측정 필요. 답이 바뀔 수 있고, 바뀌어도 원 문구와 함께 보고
RQ5 ★	확신도 게이트 캐스케이드는 그 Pareto 위의 두 점을 τ 하나로 잇는 연속 곡선으로 바꾸는가? char-CNN 급 정확도를 얼마나 싸게 살 수 있으며, 그 게이트는 최적 라우터에 얼마나 근접한가?	✅ 답 완료 (F4·F5·F6)	τ 재선택 + ECE 신설로 게이트 전제 보장
RQ2	캐스케이드는 실제 WAF 우회 기법(인코딩·주석 삽입·대소문자 변형)에 얼마나 취약한가? 나아가 정확도가 아닌 지연을 표적으로 하는 비용 기반 공격이 성립하는가?	✅ 답 완료 (F7·F8·F11)	새 트랙 기준선 재측정
RQ3	적대적 증강은 학습에서 보지 못한 변형까지 일반화되는가? 캐스케이드에서 그 대가는 어느 통화(정확도 vs 지연)로 지불되는가?	✅ 답 완료 (F9·F10·F14)	새 트랙에서 전 구성 재조립
RQ4	탐지 신호가 콘텐츠에서 사라질 때(인코딩→암호화), 내용 기반 이미지 탐지는 어디서 원리적으로 붕괴하는가?	✅ RQ4a 완료(F12) / ⚠️ RQ4b 포화(G6)	영향 적음 — 엔트로피 스윕은 데이터셋 의존이 약함
RQ6	1차와 2차의 표현 간 불일치 자체가 "회피 시도"의 탐지 신호가 되는가?	⚠️ 부분 답 — ROC-AUC 0.764, 커버리지 35.5% → 기준 0.90 미달, 보조 지표로만 보고	재측정
(RQ7 후보)	2020년 데이터로 학습한 탐지기는 2025년 실운영 공격에 얼마나 일반화되는가? (시간축 일반화)	—	Data 2025 외부셋 실험 시 RQ7 로 뒤에 추가 (번호 재배열 금지 준수)

3.3 ⚠️ 원 RQ1 문구와 HARKing 방지 원칙

RQ1 은 원래 다음과 같았다.

"이미지 기반 CNN 이 텍스트 모델과 유사하거나 더 나은 성능을 보이는가?"

실측 답은 "아니오"(F1)였다. 결과를 본 뒤 질문을 비용 축으로 바꾸는 것은 사후가설(HARKing)이 될 수 있다. → 논문 서술에서 반드시 지킬 원칙 3가지:

- 1. 원 RQ1 문구와 그 답이 '아니오'였음을 그대로 보고한다. 숨기거나 바꿔치지 않는다.
- 2. RQ5(캐스케이드)는 그 음성 결과에서 파생된 질문임을 명시한다.
- 3. Phase 12 이후의 판정 기준(H5-H6-H7)은 실측 전에 문서로 고정한다(docs/11 §7 — 이행 완료).

이렇게 쓰면 "질문을 살짝 바꾼 것"이 아니라 "음성 결과에서 출발한 설계"가 되어, 선행 8편 중 유의성 검정이 0편 인 상황(docs/12 §0)에서 오히려 방법론적 강점이 된다.

3.4 논문 서술 순서 (번호 순이 아니다)

RQ1 (음성 결과: 이미지 단독은 진다)

- ↳ RQ5 (그래서 캐스케이드 – 이 논문의 제안)
 - ↳ RQ2 (그 제안은 회피에 얼마나 버티는가 + 비용 공격)
 - ↳ RQ3 (방어를 붙이면 어떻게 되는가)
 - ↳ RQ6 (제안 구조에서만 공짜로 얻어지는 능력)

RQ4 (별도 축: 내용 기반 탐지 자체의 경계)

3.5 범위 가정

- 다중 클래스 분류(정상 / SQLi / XSS / Cmdl). 시간 부족 시 이진으로 축소 가능.
- G4 적응형 공격(방어를 알고 설계된 공격)은 수행하지 않는다 — 한계로 명시(docs/11 §9).

4. 평가지표

4.1 시기별 지표 변천 — 옛 문서를 읽을 때의 환산표

시기	헤드라인	근거 문헌	옛 문서에서 이 수치를 보면
1기 (Phase 1~6)	Accuracy · Macro-F1 · ROC-AUC	웹공격 탐지 관행	균형 데이터 가정 → 탐지력 과대평가. 참고용
2기 (Phase 7~12)	MCC · PR-AUC · benign-evasion (+Acc-Macro-F1)	MDPI <i>Technologies</i> 2026 · arXiv:2512.19203	2기 실측 기록으로 읽는다. 새 측정과 섞지 말 것
3기 (현행)	Macro-F1 · PR-AUC · TPR@FPR · pAUC · 경보부 하 · ECE + benign-evasion	Arp et al. (+지표별 개별 출처)	—

4.2 현행 지표 — 순서·역할·상태 (docs/13 §1.2)

순서	지표	역할	상태
1	Precision / Recall / Macro-F1	선행연구 직접 대조(최근 논문의 공통 통화가 F1)	기존
2	PR-AUC (AP, macro)	희귀 사건에서 ROC 보다 정보량 큼	기존
3	TPR@1%FPR · TPR@0.1%FPR	운영 지점 성능 — WAF 는 저 FPR 영역에서만 쓸 수 있다	신설

순서	지표	역할	상태
4	pAUC (FPR≤0.01 구간 정규화 ROC-AUC)	"ROC 는 감당 가능한 FPR 까지만 보라"	신설
5	경보 부하 (배포 base rate 기준 100만 요청당 오탐 수)	FPR 을 음성 클래스 base rate 와 함께 논한다	신설
6	ECE / MCE / reliability diagram	τ 게이트가 곧 확신도 임계값 → 교정 품질(단, 논거는 §4.5 로 하향)	신설
7	Accuracy, 전구간 ROC-AUC	부록	강등
—	benign-evasion (공격→Normal 오분류율)	4·5번이 그것의 운영 해석판	유지
—	~~MCC~~	—	제거

왜 경보 부하가 필요한지 — 실제로 드러난 예 (docs/13 §1.5, 합성 입력 점검): Accuracy 0.997 / Macro-F1 0.995 / PR-AUC 1.000 / ROC-AUC 1.000 인 모델도, FPR 0.03 에 배포 공격비율 0.1% 를 가정하면 **경보 정밀도가 0.032** 로 붕괴한다(100만 요청당 헛경보 29,970건 vs 진짜 1,000건). 기존 지표만 보고했다면 이 모델을 "완벽"으로 보고했을 것이다.

4.3 최근 논문이 실제로 보고하는 지표 (docs/13 §1.3)

논문	게재	보고 지표
WADBERT (Dual-channel BERT)	arXiv:2601.21893, 2026-01	F1 (CSIC2010 99.63%, SR-BH2020 99.50%)
E-WebGuard	Comput. & Secur. 148, 2025	Acc/P/R/F1 계열
WAMM	arXiv:2512.23610, 2025-12	Accuracy, 추론 속도(μs), TP 차단율

→ ① 공통 통화는 여전히 **F1** 이므로 1번에 둔다. ② 이들은 **저 FPR 운영 지점·경보 부하·교정을 보고하지 않는다** → 3·4·5·6번을 넣으면 심사 대응을 넘어 **방법론적 우위**가 된다. "지표를 바꿨다"가 아니라 **"선행연구가 안 보는 운영 지점을 본다"**로 서술할 수 있다.

4.4 ⚠️ 지표별 1차 출처가 다르다 (docs/13 §1.6 — 원문 대조 완료 2026-08-23)

논문 인용 시 이 표를 그대로 쓴다. "신설 4종은 전부 Arp et al. 권고"는 틀린 서술이다.

지표	1차 출처
TPR@FPR · pAUC	Arp et al. P7 (bounded AUC 권고) + pAUC 의 [0.5,1] 표준화는 McClish, Medical Decision Making 9(3):190–195, 1989
경보 부하	Arp et al. P8 + 계보의 원점 Axelsson, ACM CCS 1999 (doi:10.1145/319709.319710)
ECE / MCE	Naeini et al. AAAI 2015 (정의의 원점) · Guo et al. ICML 2017 (현대 신경망 평가 표준화) · CalexNet arXiv:2509.08318 (조기종료 분기 캘리브레이션 = 캐스케이드 도메인 판본)
(MCC — 제거됨)	Arp et al. P8 이 실제로 권고하는 것은 사실 — §4.6

Arp et al. 서지 확정: *Dos and Don'ts of Machine Learning in Computer Security*, **USENIX Security 2022**. 확장판 *Pitfalls in Machine Learning for Computer Security*, **CACM 67(11):104–112, 2024**, doi:10.1145/3643456 (ACM DL **Research Highlights** 게재 = CACM 편집위 선별 지면). 원문 PDF 2편 확보 완료(2026-08-23).

4.5 ⚠ ECE의 필요성 논거는 하향됐다

기존 문구 "확신도가 교정되어 있지 않으면 게이트 자체가 근거를 잃는다"는 **정확하지 않다**. τ 게이트에 필요한 것은 확신도의 **순위(ranking)** 이지 수치의 교정이 아니다. 확신도가 전부 0.99 쪽에 쏠려 있어도 val 에서 $\tau=0.995$ 로 잡히면 게이트는 정상 작동한다. → 심사에서 "val 에서 τ 를 튜닝하는데 교정이 왜 필요한가" 한 마디에 무너지는 논거다.

정정된 논거 3가지 (이것만 쓴다):

1. τ 의 이식성 — 교정돼 있어야 val 에서 고른 τ 가 다른 데이터셋·배포 환경에서 같은 의미를 갖는다. **Data 2025 외 부셋 실험이 정확히 이 검증이다.**
2. τ 의 해석 가능성 — "확신도 0.9 미만은 승급"이 실제로 "오답 확률 10%"를 뜻하는지.
3. 틀린 샘플에 과확신하는 실패의 진단 — 이걸 순위 자체를 망가뜨리므로 게이트에 실제 타격이다. 평균인 ECE 가 가리는 이 국소 실패를 **MCE** 가 드러낸다.

4.6 MCC — 제거했지만 근거는 보존한다

⚠ **먼저 사실관계:** MCC 자체는 "고등학생 지표"가 아니다. Arp et al. 은 P8 권고 절에서 "*other measures like Matthews Correlation Coefficient (MCC) are more suitable*" 라고 **명시적으로 권고**한다(원문 대조 확인). 우리 2기 트랙이 정확히 그 조건이었다 (Normal 3.4k vs 공격 각 28~40k — 공격이 인위적으로 과대표집).

그럼에도 **완전 제거로 확정**했다(2026-08-13 교수 지시 이행). 이 근거 문단을 문서에 **보존하는 이유**는 심사에서 "**왜 권고 지표를 뺐나**" 라는 역질문이 나올 때의 대응 자료이기 때문이다.

4.7 ⚠ MCC 제거의 파급 — 기준 지표 이관 (docs/13 §1.4)

MCC 는 보고 열이 아니라 **자동 의사결정의 기준값**으로 코드에 박혀 있었다. 단순 삭제하면 캐스케이드가 임계값을 못 고르고 CV 비교가 기준을 잃는다. 이관 완료된 5개 지점:

#	위치	MCC 의 역할	이관 결과
1	src/eval/metrics.py	mcc 키 산출·출력	키·출력·import 삭제 (부활 방지 테스트 있음)
2	src/eval/cv_compare.py	--metric 기본값 = paired t-test 기준	기본값 macro_f1 , choices 에서 mcc 제거
3	src/models/cascade.py	EXIT_MCC_TOLERANCE=0.0011 + 조기종료 임계값 선택 규칙	EXIT_F1_TOLERANCE 로 개명, 규칙을 Macro-F1 기준으로 재작성
4	src/models/cascade.py	H7-1 판정 기준	Macro-F1 기준으로 재서술
5	tests/test_cascade.py , test_early_exit.py	스윙 행 픽처 키	키 이름 갱신

⚠ **허용폭 0.0011 은 그대로 쓸 수 없다**. 이 값은 "단일 split 실행 간 MCC 흔들림 $\pm 0.11\text{pp}$ "를 실측해 정한 것이다 (docs/07 §2.5). 지표가 Macro-F1 로 바뀌고 데이터셋도 바뀌므로 **새 트랙에서 같은 방식으로 노이즈 폭을 재측정한 뒤** 값을 정한다. 그 전까지 조기종료 임계값 선택 결과는 신뢰하지 않는다.

4.8 구현 현황 — 무엇이 코드에 있고 무엇이 없는가

지표 **추가**는 src/eval/metrics.py 한 곳만 고치면 전 모델에 자동 반영된다 (베이스라인·CNN·ViT·캐스케이드가 같은 함수를 탄다). 지표 **제거**는 그렇지 않다(→ §4.7).

구현	위치	상태
tpr_at_fpr · partial_roc_auc · attack_operating_points	metrics.py	✅ 구현

구현	위치	상태
calibration_metrics (ece-mce-bins) · save_reliability_diagram	metrics.py	✅ 구현
alert_load (경보 부하) · attack_score	metrics.py	✅ 구현
기준값 상수 TARGET_FPRS=(0.01, 0.001) · PAUC_MAX_FPR=0.01 · DEPLOYMENT_ATTACK_PREVALENCES=(0.01, 0.001) · ECE_N_BINS=15	metrics.py	✅ 모듈 상수
CV 요약의 신설 지표 평탄화 · LOWER_IS_BETTER (ece-benign-evasion)	cross_validate.py · cv_compare.py	✅ 구현
교정 곡선 저장(cal_<tag>.png)	train.py · baseline_tfidf.py · cascade.py	✅ 구현
nan 누출 차단(_finite_or_none)	metrics.py 3곳	✅ 구현(2026-08-23)
부트스트랩 95% CI	—	❌ 미구현. docs/13 §1.2 에 "신설"로 적혀 있으나 src/ 전체에 bootstrap 문자열 0건(2026-08-23 확인) → 구현하거나 문구를 내려야 한다

검증 상태: python -m pytest tests/ -q → 168 passed (2026-08-23).

4.9 ⚠ 저 FPR 지표는 현 트랙에서 측정 불가 (docs/13 §1.7)

FPR 의 해상도는 test 셋 Normal 표본 수가 결정한다. Normal 이 N 개면 FPR 이 가질 수 있는 값은 1/N 의 배수뿐이다. 목표 FPR 이 1/N 보다 작으면 그 지점은 존재하지 않고, 코드는 "오탐 0건" 지점을 집어온다 → 사실상 "무오탐 탐지율"이 되고 표본 하나에 크게 흔들린다.

트랙	test Normal	해상도(1건당)	TPR@1%FPR	TPR@0.1%FPR
payload_4class_csicnorm (2기 주 트랙)	722	0.139pp	FP 7.2건 → 거침	❌ 정의 불가
csic_binary	726	0.138pp	거침	❌ 불가
payload_4class	8,062	0.0124pp	✅	FP 8건 → 겨우
SR-BH 2020 (예정, test 15%)	≈78,779	0.0013pp	✅	✅

pAUC(FPR≤1%)도 같은 제약을 받는다 — 722개 트랙에서는 그 구간에 들어오는 음성이 약 7개뿐이라 계단 몇 칸짜리 값이 되어 비교 근거로 쓸 수 없다.

→ 결론 2가지

- 신설 지표 3종(TPR@FPR·pAUC·경보부하)은 데이터셋 교체와 세트로만 성립한다. 현 트랙에서 미리 돌려 논문에 실는 것은 위험하다. 이걸 오히려 교수 지시 2건(지표·데이터셋)이 왜 한 묶음이어야 하는지에 대한 논거가 된다.
- 논문에 저 FPR 지표를 실을 때는 Normal 표본 수를 반드시 함께 표기한다.

외부 검증셋(Data 2025)에서의 지표 가용성 — 악성만 있고 정상이 없다.

지표	외부셋
Recall(탐지율) · benign-evasion	✅
ECE / MCE	✅ (확신도 vs 정답 여부만 필요) → §4.5-1 의 τ 이식성 검증 핵심

지표	외부셋
TPR@FPR · pAUC · 경보부하 · FPR	❌ 음성 표본이 없어 정의 불가

5. 데이터셋

5.1 지금까지 실제로 쓴 트랙 (1~2기 — 현재 `experiments/results/` 의 근거)

트랙	구성	train / val / test	test 클래스 분포	용도
<code>payload_4class</code>	Kaggle 페이로드 단독 (206,636 행 → 중복 제거 199,793)	139,855 / 29,969 / 29,969	CmdI 7,202 · Normal 8,062 · SQLi 8,592 · XSS 6,113	RQ1 초기
<code>payload_4class_csicnorm</code> ★	공격=Kaggle, Normal=CSIC 2010 실트래픽 (156,115행 → 150,855)	105,598 / 22,628 / 22,629	CmdI 7,202 · Normal 722 · SQLi 8,592 · XSS 6,113	2기 주 트랙 — F1~F14 대부분의 근거
<code>csic_binary</code>	CSIC 2010 단독 이진 (61,065행 → 중복 77.9% 제거 → 13,498)	9,448 / 2,025 / 2,025	Anomalous 1,299 · Normal 726	보조
<code>ustc_flow_binary</code>	USTC-TFC2016 세션 → 앞 2304B → 48×48	—	—	RQ4b (F1 0.9999 포화 → 부록 강등, G6)

공통: train/val/test = 70/15/15, stratified, **seed=42 결정론**. 완전 중복 제거 후 분할. 클래스 불균형 트랙은 `train.py --balance` (train 만 언더샘플링, val/test 는 실분포 유지).

⚠️ `payload_4class_csicnorm` 의 구조적 약점이 곧 교체 사유다 — "합성 공격 페이로드 + CSIC 정상 트래픽"을 억지로 붙인 조합이고, Normal 이 722개(test)뿐이라 §4.9 의 저 FPR 지표가 성립하지 않는다.

5.2 Phase 13 확정 구성 (docs/13 §2.4) — 아직 미착수

역할	데이터셋	연도	용도	상태
주 트랙	SR-BH 2020	2020	RQ1·RQ2·RQ3·RQ5·RQ6 전부의 새 측정 기반	⌚ 다운로드부터 미착수
외부 검증	Data 2025 (Zenodo)	2025	시간축 일반화 탐지율(정상 없음 → recall 전용)	⌚ 미착수
legacy 대조	CSIC 2010	2010	선행연구(E-WebGuard·WADBERT) 직접 대조용, 부록/비교표	보유
페이로드 보강	Kaggle SQLi·XSS·CmdI + PayloadsAllTheThings	—	RQ2 회피 변형 생성 재료로 유지	보유
흐름 (RQ4b)	USTC-TFC2016	2016	포화 → 부록 강등(G6 결정 유지)	보유

SR-BH 2020

Riera, Higuera, Higuera, Herraiz, Montalvo. *A new multi-label dataset for Web attacks CAPEC classification using machine learning techniques*. **Computers & Security 120 (2022) 102788**. doi:10.1016/j.cose.2022.102788 · 배포: Harvard Dataverse doi:10.7910/DVN/OGOIXX

- 수집: 2020-07, 12일간, 인터넷에 **실제 노출된** WordPress 서버

- 라벨링: ModSecurity 2.9.2 + **CRS 3.3.0** detection-only 기록 → **수동/반자동 검수로 교정**
- 규모: **907,814 요청** (정상 525,195 / 이상 382,619), 24 features + **13 라벨**(멀티라벨 CAPEC)
- 최근 사용: E-WebGuard(2025), WADBERT(2026-01), WAMM(2025-12)
- ☒ **우리 파이프라인 적합성:** 배포본에 `request_http_request (URI)` · `request_body` · `request_user_agent` · `request_cookie` 등 **원문 문자열 컬럼이 살아 있다** → 바이트→48×48 변환이 **수정 없이 동작**. ⚠ 원 논문의 **방법**은 필드별 ASCII 평균으로 24개 수치를 뽑는 것이라, 이 구분을 놓치면 "인코딩된 수치뿐이라 이미지화 불가"로 오판한다.

Data 2025

Lucz, G., Forstner, B. *A Thirty-Day Dataset of Malicious HTTP Requests Blocked by OWASP ModSecurity on a Production Web Server*. **Data 2025, 10(11), 186**. doi:10.3390/data10110186 배포: Zenodo 10.5281/zenodo.17178461 (owasp.zip , 29.5 MB, **CC-BY 4.0**)

- 2025년 실운영 서버에서 OWASP CRS 가 실제 차단한 악성 요청 30일분
- 익명화하되 method / URI / 헤더 / user-agent / 발동 rule ID **구조 보존** → 원문 바이트 사용 가능
- ⚠ **악성만 있고 정상이 없다** → FPR 계산 불가. **탐지율(recall) 전용 외부 테스트셋**으로만 쓴다.

왜 이게 지시 ②의 진짜 답인가: 2020년판으로 바꾸는 것만으로는 "그것도 6년 전"이라는 같은 지적을 다시 받는다. 대신 **2020년 데이터로 학습 → 2025년 실운영 공격 탐지율**을 보고하면, "최신성"을 데이터 연도가 아니라 **측정된 일반화 결과**로 답하게 된다.

5.3 CSIC 2010 은 왜 강등이고 삭제가 아닌가

문헌에서 확인된 실제 한계: **단일 도메인·단일 머신** 트래픽 / 공격 유형 수가 매우 제한적이고 **세부 공격 유형 라벨이 없어** 선행연구가 대체로 **이진 분류**에 머뭇 / 정상 트래픽이 **합성**. → 논문에는 "2010년이라서"보다 **구성 자체의 한계**로 쓰는 게 강하다.

⚠ 다만 **CSIC 2010 은 2025~2026 최신 논문에서도 여전히 보고된다**(E-WebGuard 2025, WADBERT 2026 둘 다 CSIC 2010 + SR-BH 2020 병기). 삭제하면 **선행연구와 대조할 통화를 잃는다** → 강등 + 병기.

5.4 CAPEC 13라벨 → 4클래스 매핑 (docs/13 §2.5, 2026-08-13 확정)

SR-BH 라벨 (CAPEC)	우리 클래스
000 Normal	Normal
66 SQL Injection	SQLi
242 Code Injection	XSS(→ 권고: CodeInj 로 표기)
88 OS Command Injection	CmdI
나머지 9라벨 (Path Traversal, Scanning, Verb Tampering, HTTP Response Splitting, ...)	제외(또는 부록 별도 보고)

- ⚠ **코드로 못박아야 할 규칙 3건** (나중에 "왜 이 수치인가"를 재현할 근거):
1. **242 Code Injection → XSS 는 완전한 동의어가 아니다.** CAPEC-242 는 코드 주입 일반이며 XSS 를 포함하지만 더 넓다. → **CodeInj** 로 표기하고 "XSS 를 포함하는 상위 범주"로 명시. 이름을 XSS 로 두면 **과대주장**이 된다.
 2. **멀티라벨 → 멀티클래스 축약 규칙.** 대상 4클래스 중 2개 이상이 붙은 요청은 **모호 표본으로 제외**하고 제외 건수를 보고.
 3. **제외된 9라벨 요청의 처리.** Normal 로 넣으면 안 된다(그건 공격이다) → **데이터셋에서 제외**하고 규모를 보고. ⚠ 이걸 Normal 로 흘리면 §5.5 의 라벨 노이즈를 우리 손으로 재현하게 된다.

5.5 ⚠️ 알려진 리스크 — SR-BH 2020 의 라벨 노이즈

Osama et al. *Enhanced Web Payload Classification Using WAMM*. [arXiv:2512.23610](#), 2025-12 (rev. 2026-01)

이 논문의 감사 결과 **정상**으로 **잘못 라벨된 악성 요청 48,522건**(정상 525,195건의 **약 9.2%**). LLM 판정 후 웹 침투테스트 전문가가 300여 표본을 수동 검증(LLM 판정과 100% 일치)했다고 보고한다.

대응 방침 3가지

- 1. 착수 시 **우리 자체 감사**를 먼저 돌린다(정규식 기반 SQLi/XSS/CmdI 시그니처로 정상 클래스 스캔) → 규모를 **우리 손으로 재현 확인**한 뒤 수치를 인용.
- 2. **정제 전/후를 병기 보고**한다. 라벨 노이즈를 숨기지 않는 것 자체가 방법론 점수다.
- 3. ⚠️ 노이즈는 **정상 클래스에 악성이 섞인** 방향 → benign-evasion 과 FPR 을 **낙관적으로** 왜곡한다. 우리 헤드라인이 정확히 그 지표들이므로 이 감사는 **선택이 아니라 필수**다.

5.6 이미지 변환 (데이터셋이 바뀌어도 그대로)

- **Step 1** 정규화: 페이로드 문자열 → UTF-8 바이트 시퀀스
- **Step 2** 2D 리셰이프(Nataraj 방식): 고정 폭 48 → 48×48. 짧으면 zero-padding, 길면 truncation. 픽셀 = 바이트값 0~255 → 0~1 정규화. 픽셀 (r,c) ↔ 바이트 오프셋 `r*48+c` 는 **전단사**(Grad-CAM 역변환 근거)
- **Step 3** RGB 채널: **R = raw byte / G = 문자 클래스 / B = local n-gram 엔트로피**. 인코더는 `src/imaging/channel_encoders.py` 레지스트리(교체형 ablation)

6. 기존 실측 F1~F14 — 무엇이 어떤 지표로 측정됐나

⚠️ 아래 수치는 전부 2기 기준(주로 `payload_4class_csicnorm`, MCC 헤드라인)이다. 데이터셋 교체 시 `experiments/results/` 의 141개 JSON 전부와 그로부터 파생된 그림·문구가 무효화된다. **살아남는 것은 코드·아이디어·방법론 전부** — 트랙만 갈아끼우면 그대로 동작한다.

#	확정 사실	수치 (2기 실측)	출처	지표
F1	이미지화 CNN 은 텍스트 베이 스라인에 유의하게 열세	char-CNN 0.9944±0.0004 vs RGB CNN 0.9762±0.0025, adj p=0.0010~0.0247	docs/04 §5.1	MCC
F2	gray→RGB 개선은 진짜 (CV 확정)	0.9493 → 0.9762 (+ 2.69pp), adj p=0.0037~0.0201	docs/07 §2.5	MCC
F3	RGB 채널 조합 간 우열은 판정 불가	6쌍 전부 adj p ≥ 0.88	docs/07 §2.5	MCC
F4	clean 탐지 상보성 이득 없음	캐스케이드 vs char-CNN 탐지집합 완전 동일 (둘 다 놓침 8건)	docs/09 §9.6	탐지집합
F5	캐스케이드는 같은 정확도를 5.07배 싸게	esc 7.99%, F1 0.9934 / MCC 0.9907, 0.0111 ms	docs/09 §9.2	MCC + 지연
F6	확신도 게이트는 나쁜 라우터	oracle esc 1.87% vs 실측 27.73% (14.8배 과잉)	docs/09 §9.4	에스컬레이션
F7	비용 기반 공격 실재	저에스컬레이션 운영점에서 2.54%→5.50%(2.17배), SLA 붕괴	docs/09 §9.5	에스컬레이션
F8	benign-evasion 은 전 모델-전 구성 바닥 (~0)	0.0000~0.0022, 방어 후에도 동일	docs/05 §13.2	benign-evasion

#	확정 사실	수치 (2기 실측)	출처	지표
F9	적대적 증강은 본 변형만 암기 하며 그 정도는 표현에 의존	S-0 -44.20pp vs S-A -4.80pp. S-A/S-0 비: 이미지 7.0~43.9% (미달) vs 텍스트 41.7~ 54.0%	docs/10 §11.2	any-misclass
F10	캐스케이드는 방어 비용을 지연으로 지불	clean MCC -0.12pp인데 esc 34.97%→ 69.52%	docs/10 §11.3	MCC + esc
F11	변형 하 동요를 만드는 것은 사실상 3중	<code>space_to_comment</code> +0.635, <code>url_encode</code> +0.584, <code>double_url_encode</code> +0.572	docs/10 §11.2	any-misclass
F12	탐지를 죽이는 것은 엔트로피가 아니라 랜덤화(키)	S3 고정키 XOR F1 0.9445 유지 → S4 AES 0.3965 붕괴	docs/06 §5.5	F1
F13	ViT/hybrid 는 채택 안 함	hybrid vs CNN 평균차 +0.12pp, p(adj)=1.0000	docs/08 §9.4	MCC
F14 ★	비학습 정규화(B)가 학습형 증강(A)을 이긴다 — 미지 변형 조건	RGB CNN 0.2112 vs 0.4693/0.5704, char-CNN 0.0650 vs 0.1176/0.1383. 단 B 는 이미지 표현에서 clean MCC -1.04pp 지불	docs/10 §11.5	any-misclass

6.1 Phase 12 확장 3안 (docs/11 §16)

방안	무엇을 시도했나	판정	핵심 수치	논문에서의 자리
M1 표현 불일치	1·2차 예측 불일치를 회피 시도 신호로	⚠ 보조 지표로 하향	ROC-AUC 0.764 (기준 0.90), 커버리지 35.5%, 추가 비용 0	RQ6 부분 답 · 기여 C5
M2 인코딩 불변 채널	%XX · &#NN 해독 후 문자 클래스를 G 채널로	⚠ 단독 미채택 / 증강 결합 채택	단독 0.4707→ 0.5552 (악화) · 증강 결합 S-A 0.4227→ 0.1833	RQ3 보강 · 기여 C6·C7
M4 다단 조기 종료	1차 비용 <code>C_cnn</code> 자체를 낮춰 속도 천장 돌파	❌ 미채택	연산 18% 생략했는데 시간 +3.3% , speedup 5.07→ 3.99배	한계로 정직 보고
(M3) CAM 크롭	—	● 미착수	—	후보로만 남음

부정 결과 2건(M4-ViT/hybrid)을 숨기지 않는다 — 오히려 C1("1차가 이미 충분히 싸다")의 근거를 강화한다.

7. 논문이 주장하는 기여 — 확정 문구와 금지어 (마스터 §11)

이 표의 왼쪽 문구를 그대로 쓰고, 오른쪽은 쓰지 않는다. 선행 대조로 이미 하향된 결과다.

#	기여	✅ 쓸 문구	❌ 금지 문구
C1	표현 이질적 캐스케이드	"이미지 표현과 텍스트 표현을 잇는 캐스케이드로, 같은 정확도를 5.07배 싸게 얻는다"	"이미지 기반이 더 정확하다"
C2	τ 연속 스펙트럼	" τ 하나가 clean 정확도뿐 아니라 공격 하 강건성에서도 두 단독 모델 사이를 연속 이동한다(0.364↔0.556)"	—
C3	problem-space slowdown 공격	"DeepSloth 가 보인 slowdown 공격이 웹공격 탐지 캐스케이드에서도 성립함을 실측했다. 단 모델 접근 없이, 실제로 동작하는 페이로드 변형만으로 2.17배"	"새로운 공격면을 발견 했다"
C4	게이트 품질의 상한 정량화	"확신도 게이트는 oracle 대비 14.8배 과잉 공급한다 — 개선 여지의 상한을 못 박았다"	—

#	기여	✅ 쓸 문구	❌ 금지 문구
C5	표현 불일치 회피 탐지 ⚠️ 하향	"추가 비용 정확히 0(모드 A)으로 회피 시도의 보조 신호를 낸다 (ROC-AUC 0.764, 커버리지 35.5%)"	"표현 불일치를 쓰는 것이 새롭다" · "회피 시도를 탐지한다" · "실용적이다"
C6	인코딩 불변 채널 + 증강 ⚠️ 조건부	"단독으로는 듣지 않지만, 적대적 증강과 결합하면 미지 인코딩 변형 일반화를 10.9%→69.2% 로 끌어올린다(clean 대가 -0.02pp)"	"인코딩 불변 채널이 회피를 막는다" · "정규화 방어를 대체한다" · "F9 를 해결했다"(→ 부분적으로 뒤집었다)
C7	인코딩 회피의 작동 원리 진단	"인코딩 회피의 위력은 바이트 값이 아니라 길이 팽창에 따른 2차원 배치 밀림에서 온다"	"길이가 유일한 원인이다"

⚠️ 속도 배수는 2차 기준 모델을 명시해 병기한다 — 우리 5.07배 vs Tasdemir 20배는 기준이 BERT 라 직접 비교 불가.

정직하게 함께 쓸 한계: 이미지 단독은 텍스트 모델에 유의하게 진다(F1) / clean 탐지 상보성 이득 없음(F4) / 적대적 증강은 본 변형만 암기(F9) / 소규모 배포에서는 char-CNN 단독으로 충분 / 적응형 공격 미수행(G4) / 성능 차이는 표면 토 큰 포화 상태의 트랙에서 측정됨 / 조기종료 1차 미채택(M4) / 적대적 증강 방어를 켜면 C5 의 불일치 신호가 지워진다 (0.764→0.598) / M2 단독은 회피를 오히려 쉽게 만든다(0.5981→0.6550) / M2 를 켜면 비용 기반 공격 표면이 넓어진다 (esc 35.39%→77.71%)

8. 남은 작업 — 순서

GPU 는 1대뿐 → 학습 작업은 순차 실행 필수.

순서	작업	상태
1	SR-BH 2020 Dataverse 다운로드 → 포맷·용량·라이선스 직접 확인	⌚ ⚠️ 2026-08-13 에 한 기기에서 Dataverse API 조회가 네트워크 차단으로 실패 → 브라우저 또는 다른 기기에서 재확인
2	<code>src/data/download_srbh.py</code> · <code>download_owasp2025.py</code> 신설 + <code>.gitignore</code> 에 <code>data/raw/<신규></code> 추가 후 <code>git check-ignore -v</code> 확인	⌚
3	SR-BH 라벨 노이즈 자체 감사(\$5.5) → 48,522건 규모 재현 확인	⌚
4	CAPEC→4클래스 매핑 구현(\$5.4 규칙 3건) + 제외 건수 보고	⌚
5	새 트랙 <code>preprocess.py</code> → <code>build_image_dataset.py</code> (⚠️ --track choices 5곳 동시 갱신)	⌚
6	부트스트랩 95% CI 구현 또는 문서 문구 하향(\$4.8)	⌚
7	Macro-F1 노이즈 폭 재측정 → <code>EXIT_F1_TOLERANCE</code> 확정(\$4.7)	⌚ 새 트랙 준비 후
8	RQ1 본 측정(모델 6종 + TF-IDF) → 5-fold CV	⌚
9	캐스케이드 τ 재선택 + ECE	⌚
10	RQ2 / RQ3 회피·방어 재측정	⌚
11	Data 2025 외부 탐지율(= RQ7 후보)	⌚
12	legacy CSIC 2010 대조표(선행연구 비교용, 축소 구성)	⌚
13	마스터 §3 데이터셋 표를 §5.2 로 갱신 · docs/12 §1 에 Phase 13 인용문헌 등재	⌚

9. 자주 헛갈리는 것 — 빠른 대조표

마주친 것	어떻게 읽어야 하나
옛 문서에서 MCC 수치를 봤다	2기 실측 기록이다. 그대로 보존하되 새 측정과 섞지 않는다. 현행 기준 지표는 Macro-F1
문서에 "제안 CNN" 이라고 쓰여 있다	옛 표기다. 제안 모델은 캐스케이드. 문맥상 1차 부품이면 RGB CNN 으로 읽는다
회피율 0.594 / 0.5944 / 0.0022	gray CNN 실측이다. RGB 기준선은 0.5981
hybrid 라는 말	docs/08 의 모델 아키텍처(CNN stem+Transformer, 미채택). 배치 구조인 cascade 와 다른 것
ECE 는 Arp et al. 권고라고 쓰여 있다	❌ 오귀속. 원문에 언급 0건. Naeini 2015 · Guo 2017 로 인용(\$4.4)
TPR@0.1%FPR 수치가 나왔다	현 트랙(Normal 722)에서는 정의 불가. SR-BH 교체 후에만 유효(\$4.9)
문서에 부트스트랩 95% CI 가 "신설"로 적혀 있다	미구현이다(src/ 에 bootstrap 0건). 문서가 앞서 나간 상태(\$4.8)
experiments/results/*.json 의 수치	2기 기준. 데이터셋 교체 시 141개 전부 무효화 — 코드·방법론은 그대로 산다
docs/reports/thesis_onepass_2026-08-12	Phase 13 이전 판. 흐름·기여 문구는 유효, 지표·데이터셋 절은 이 문서로 갱신해 읽을 것
docs/07 §1.3 (지표 모범사례)	Phase 13 으로 대체됨. 두 문헌은 보조 근거로만 남음
RQ 번호를 정리하고 싶다	❌ 재배열 금지. 파일명에 박혀 있다. 새 질문은 뒤 번호(RQ7~)로 추가

10. 이 문서의 유지 규칙

- 새 사실을 여기서 만들지 않는다. 결정은 해당 Phase 문서(docs/0N_*.md)에 먼저 남기고, 여기에는 요약과 포인터만 옮긴다.
- 마스터 설계 문서(docs/web_attack_image_cnn_thesis_design.md)와 어긋나면 마스터가 옳다 — 단, 지표·데이터셋 만은 docs/13 이 최신이다.
- 데이터셋 교체가 실행되면 §5.1(옛 트랙) → §5.2(새 트랙)로 무게를 옮기고 §6 표에 재측정 완료 열을 추가한다.

개정 이력

날짜	내용
2026-08-24	신설. 1~3기 구분, RQ·지표·데이터셋 통합 정리, 자주 헛갈리는 것 대조표

재생성 (PDF)

이 문서가 원본(Markdown) 이고 PDF 는 산출물이다. 내용은 .md 를 고치고 다시 굽는다. pandoc · wkhtmltopdf 는 이 프로젝트에 없으므로 python-markdown → HTML → Chrome 헤드리스로 굽는다. Chrome 은 상대 경로 출력에서 액세스 거부가 나므로 입출력 모두 절대 경로로 넘긴다. 산출물은 docs/reports/current_baseline_2026-08-24.pdf , 굽는 절차는 docs/reports/README.md 의 "PDF 재생성" 절을 따른다(경로는 git rev-parse --show-toplevel 로 그때그때 구할 것).